Curso Administración, integración y operación de Keycloak

Contraloría General de la Republica

OCTUBRE 2026

Formacion TI SpA

PRESENTACION

Instructor: Patricio Canelo Estay

Alumnos :

Agenda

Parte 1) Fundamentos a Identidades IAM, IGA, IdP, IdM y arquitectura.

Parte 2) Instalación de Keycloak. Inicio de realms y clients: Realms, clientes, roles, grupos, scopes, mappers y claims. Introducción OAuth 2.0/OIDC.

Parte 3) Authorization Code + PKCE, Client Credentials, Service Accounts, Refresh Tokens y JWT/JWKS. Inicio de User Federation.

Parte 4) LDAP/Active Directory, sincronización y mappers. MFA, flujos de autenticación e Identity Providers.

Parte 5) Identity Brokering, OIDC/SAML, SSO/SLO e integración de aplicación web y API REST.

Parte 6) Seguridad, auditoría, troubleshooting, operación productiva, reverse proxy y alta disponibilidad. Cierre integrador.

BLOQUE I — FUNDAMENTOS DE IAM

PARTE 1
Fundamentos de Identity and Access Management (IAM)

Identidad • Autenticación • Autorización • Federación

Fundamentos para continuar con Keycloak

Octubre de 2026

Objetivos de Aprendizaje

1. Dominar Conceptos IAM

• Distinguir identidad digital, cuentas, credenciales, roles y permisos.

• Diferenciar identificación, autenticación, autorización y sesión.

• Separar conceptualmente SSO de la federación de identidades.

2. Arquitectura Empresarial

• Delimitar responsabilidades de IdM, IdP, IGA y PAM.

• Diferenciar User Federation (repositorios externos) frente a Identity Brokering.

• Comprender la función de Keycloak como IdP sin sustituir API Gateways.

3. Flujos de Tráfico Moderno

• Modelar seguridad North-South (perimetral e interactiva).

• Asegurar tráfico East-West (entre microservicios/workloads).

• Articular OAuth 2.0, OIDC, SAML 2.0 y mTLS en Zero Trust.

¿Qué es IAM y qué problemas resuelve?

Desafíos Tradicionales (Sin IAM)

- Silos aislados de identidades por cada aplicación.
- Cuentas huérfanas tras desvinculación laboral.
- Fatiga de contraseñas y reutilización de claves débiles.
- Acumulación descontrolada de accesos (Access Creep).
- Imposibilidad operativa de auditar quién accede a qué.

Valor Estratégico de IAM

- Gestión coordinada de identidades y accesos, con integración de repositorios.
- Automatización del ciclo de vida Joiner-Mover-Leaver.
- Experiencia de usuario unificada con SSO y MFA adaptativo.
- Apoyo al principio de mínimo privilegio mediante políticas y revisiones.
- Trazabilidad probatoria y cumplimiento normativo estricto.

IAM como Componente Fundamental de Ciberseguridad

Superficie de Amenazas Críticas

- Ataques de Credential Stuffing y Password Spraying.
- Campañas de Spear-Phishing dirigidas con ingeniería social.
- Movimiento lateral tras comprometer estaciones de trabajo.
- Exfiltración de credenciales hardcodeadas en scripts y código.

Controles Defensivos IAM

- Autenticación robusta resistente a phishing (FIDO2 / WebAuthn).
- Políticas de acceso contextual y evaluación adaptativa de riesgo.
- Desaprovisionamiento sincronizado en tiempo real.
- Alineación con normas y requisitos regulatorios aplicables según jurisdicción.

Componentes de una Arquitectura IAM Moderna

Access Management / IdP

• Autenticación en tiempo de ejecución (Runtime).

• Single Sign-On (SSO) y Single Logout (SLO).

• Emisión y validación de tokens OIDC y SAML.

• Gestión de sesiones e interfaces de usuario.

Identity Governance (IGA / IdM)

• Aprovisionamiento y sincronización de cuentas.

• Workflows de solicitud y aprobación de negocio.

• Recertificación periódica de privilegios.

• Segregación formal de funciones (SoD).

Privileged Access (PAM)

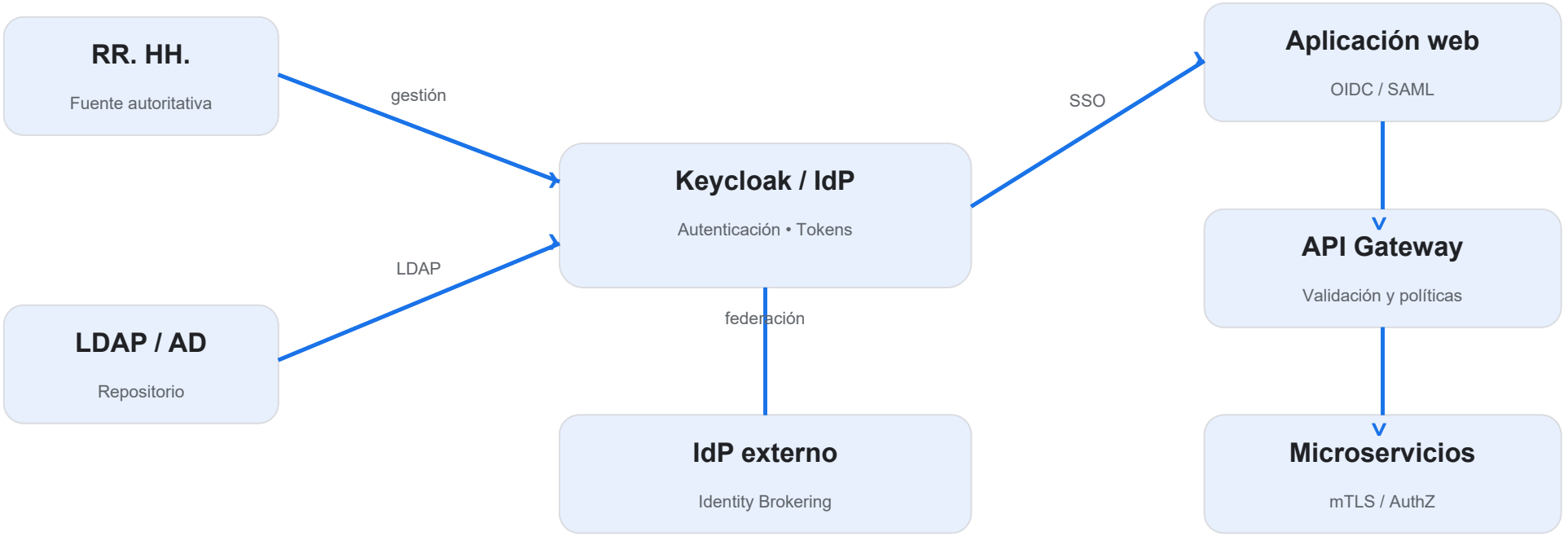
• Bóvedas seguras de credenciales de alta jerarquía.

• Aislamiento y grabación en video de sesiones RDP/SSH.

• Elevación temporal Just-in-Time (JIT).

• Rotación automática de passwords administrativos.

Diagrama General de Arquitectura IAM Empresarial



Identidad Digital: Definición, Atributos e Identificadores

Identificador Inmutable

• Identificador estable dentro del dominio de identidad y su ciclo de vida.

• Puede usar identificadores opacos estables; UUID v4 es una opción, no obligación.

• Garantiza integridad histórica en auditorías.

• Evita colisiones tras fusiones corporativas.

Atributos Calificados

• Datos de perfil (Nombre, Apellidos, Teléfono).

• Correo electrónico institucional (MUTABLE).

• Estructura organizacional (Departamento, Cost Center).

• Cargos, designaciones y puestos funcionales.

Regla de Oro de Arquitectura

• NUNCA use atributos mutables como identificador primario.

• Si un empleado cambia de apellido o cambia el dominio de email, la clave primaria no debe alterarse.

• El claim sub identifica al usuario de forma localmente única por emisor (iss).

Identidades Humanas y No Humanas (NHI)

Identidades Humanas

- Usuarios físicos (Empleados, Contratistas, Clientes B2C).
- Interacción interactiva basada en navegador o app móvil.
- Autenticación sujeta a factores biométricos y posesión.
- Vulnerables a phishing, fatiga MFA y robo de sesión.
- Sesiones temporales sujetas a horarios y actividad.

Identidades No Humanas (NHI / Workloads)

- Microservicios, procesos batch, scripts, pipelines CI/CD.
- Cuentas de servicio, bots, Daemons y dispositivos IoT.
- Autenticación automatizada vía certificados x509 o tokens M2M.
- Riesgo crítico de exposición en repositorios y logs.
- Operación desatendida 24/7 sin interacción visual.

Identity Management (IdM): Concepto y Responsabilidades

Funciones Clave de IdM

- Consolidación de identidades desde sistemas de RRHH.
- Aprovisionamiento y desaprovisionamiento automatizado.
- Sincronización mediante el estándar SCIM 2.0.
- Gestión y normalización de esquemas de atributos.

Diferenciación Técnica: IdM vs IdP

- El IdM administra el registro de la persona (Backend administrativo).
- El IdP procesa la autenticación interactiva (Frontend runtime).
- IdM determina qué cuentas deben existir; IdP emite tokens de acceso.
- Keycloak es fundamentalmente un IdP, no un IdM corporativo completo.

Ciclo de Vida de Identidad: Joiner, Mover, Leaver (JML)

Joiner (Ingreso)

• Creación de la cuenta en el directorio autoritativo.

• Asignación del perfil base según departamento y cargo.

• Generación de credenciales iniciales de un solo uso.

Mover (Transición)

• Modificación de atributos tras cambio de rol o área.

• Revocación obligatoria de privilegios del rol anterior.

• Asignación de las nuevas atribuciones operativas.

Leaver (Desvinculación)

• Deshabilitación inmediata de cuentas en todos los repositorios.

• Terminación de sesiones y revocación según capacidades y alcance del sistema.

• Eliminación o archivado de accesos para evitar cuentas huérfanas.

LDAP y Active Directory como Repositorios de Identidad

Características del Árbol DIT

• Estructura jerárquica optimizada para búsquedas masivas.

• Modelo X.500: Base DN, Organizational Units (OU), Objetos (CN/UID).

• Operaciones nativas: Bind (autenticar), Search (consultar atributos).

• Proteger LDAP con TLS: LDAPS o StartTLS, según configuración.

Limitaciones en la Nube y Web

• Protocolo binario no apto para llamadas HTTP/REST o SPAs.

• Inadecuado para atravesar proxies web o redes móviles.

• No soporta emisión nativa de tokens JWT ni aserciones de acceso.

• Puede actuar como repositorio de identidad integrado con un IdP.

Diferencias: Identidad, Cuenta, Credencial, Rol y Permiso

Identidad vs Cuenta vs Credencial

• Identidad: El individuo o entidad única (ej. Juan Pérez).

• Cuenta: Registro informático específico en un sistema (ej. jperez_adm).

• Credencial: El elemento probatorio de autenticación (ej. Clave FIDO2).

Rol vs Permiso

• Rol: Colección lógica de funciones de negocio (ej. 'Auditor Financiero').

• Permiso: Privilegio técnico atómico sobre un objeto (ej. 'reports:export').

• Una identidad posee una o más cuentas; la cuenta tiene credenciales y asume roles que otorgan permisos.

Identificación versus Autenticación

Identificación (Declaración)

- El sujeto declara quién afirma ser.
- Dato típicamente público o semi-público.
- No confiere certeza técnica por sí mismo.
- Ejemplo: Escribir el username 'jdoe' o el UUID en un formulario.

Autenticación (Demostración)

- El sistema verifica la prueba criptográfica o el secreto presentado.
- Determina el nivel de certeza de la identidad (AAL según NIST).
- Establece una relación de confianza válida para la sesión.
- Ejemplo: Firmar un desafío criptográfico con una clave privada FIDO2.

Factores de Autenticación y Mecanismos Habituales

Algo que Sabes (Conocimiento)

• Contraseñas, frases de paso, PIN numérico.

• Vulnerables a robo por keyloggers, phishing y fuerza bruta.

• Preguntas de seguridad (DECLARADAS OBSOLETAS por NIST).

Algo que Tienes (Posesión)

• Llave física de hardware (YubiKey con FIDO2).

• Aplicación generadora de códigos TOTP (RFC 6238).

• Tarjeta inteligente criptográfica con chip.

Algo que Eres (Inherencia)

• Huella dactilar, escaneo de iris, biometría facial.

• No revocables en caso de compromiso.

• Su tratamiento requiere protección de plantillas y comprobación adecuada.

MFA, FIDO2, WebAuthn y Resistencia al Phishing

MFA Vulnerable a Proxy Inverso (AiTM)

• Ataques Adversary-in-the-Middle (herramientas como Evilginx).

• El atacante intercepta la clave y el código TOTP en tiempo real.

• El usuario entrega el token en un dominio fraudulento.

• El atacante roba la cookie de sesión definitiva emitida por el IdP.

MFA Resistente al Phishing (FIDO2 / WebAuthn)

• Basado en criptografía de clave asimétrica vinculada al origen.

• El navegador vincula la firma al dominio exacto (Relying Party ID).

• Un autenticador ligado al RP ID legítimo no produce una autenticación válida para un origen fraudulento.

• Estándar promovido por la FIDO Alliance y W3C.

Diagrama de Secuencia de Autenticación Mediante un IdP



Autorización: Sujetos, Recursos, Acciones y Políticas

Elementos de la Decisión de Acceso

• Sujeto (S): Identidad autenticada que realiza la petición.

• Recurso (R): Objeto o entidad que se desea manipular.

• Acción (A): Operación solicitada (Read, Write, Delete, Approve).

• Contexto (C): Factores ambientales (IP, hora, postura del dispositivo).

Arquitectura de Decisión (XACML / NIST 800-207)

• PDP (Policy Decision Point): Motor que evalúa la política y emite Permit/Deny.

• PEP (Policy Enforcement Point): Componente que bloquea o permite el tráfico en la app.

• El Access Token aporta credenciales; el PEP/PDP ejecuta la autorización real.

Modelos de Autorización: RBAC y ABAC

RBAC (Role-Based Access Control)

• Permisos asociados estrictamente al rol funcional del usuario.

• Fácil de implementar y auditar en sistemas sencillos.

• Desventaja crítica: 'Role Explosion' al modelar casos particulares.

• Ejemplo: Rol 'Contador' puede emitir facturas.

ABAC (Attribute-Based Access Control)

• Evaluación dinámica de políticas basadas en atributos multidimensionales.

• Combina atributos del sujeto, recurso, acción y entorno.

• Alta flexibilidad para Zero Trust y contextos modernos.

• Ejemplo: Permitir lectura SI rol='Médico' Y médico.área == recurso.área Y hora < 20:00.

Autenticación versus Autorización: Comparación y Ejercicio

Matriz Comparativa

• AuthN: Responde a '¿Quién eres?'. Resuelta en el IdP central.

• AuthZ: Responde a '¿Qué puedes hacer?'. Resuelta en el recurso/PEP.

• HTTP 401 suele indicar credenciales ausentes, inválidas o insuficientes.

• HTTP 403 indica que el servidor rechaza la operación; no prueba por sí solo autenticación previa.

Ejercicio Conceptual (Análisis en 2 minutos)

• Escenario 1: Un empleado inicia sesión con clave y FIDO2 válidos, pero recibe HTTP 403 al ver un reporte. ► ¿Qué actuó? (Respuesta: AuthN fue exitosa; AuthZ denegó la acción).

• Escenario 2: Una llamada a una API presenta un token con la firma criptográfica corrupta o vencida. ► ¿Qué falló? (Respuesta: Fallo de verificación de credencial / AuthN en el Gateway).

Mínimo Privilegio y Zero Trust en el Contexto IAM

Tres Pilares de Zero Trust (NIST SP 800-207)

• 1. Verificar explícitamente: Autenticar y autorizar siempre según el contexto.

• 2. Usar mínimo privilegio: Otorgar acceso Just-in-Time (JIT) y Just-Enough-Access (JEA).

• 3. Asumir la brecha: Minimizar el radio de explosión mediante segmentación.

Eliminación de 'Standing Privileges'

• Reducir privilegios permanentes donde sea viable según riesgo operacional.

• Los accesos críticos deben activarse por demanda temporal aprobada.

• Reevaluación continua de la postura de seguridad de la sesión.

• Revocación automática si el dispositivo pierde la conformidad de seguridad.

Concepto de Single Sign-On (SSO)

¿Cómo opera el SSO?

• Propiedad que permite autenticarse una sola vez en un IdP central.

• El IdP establece una sesión central respaldada por cookies seguras.

• Otorga acceso subsiguiente a múltiples aplicaciones independientes.

• Evita que el usuario deba reingresar sus credenciales repetidamente.

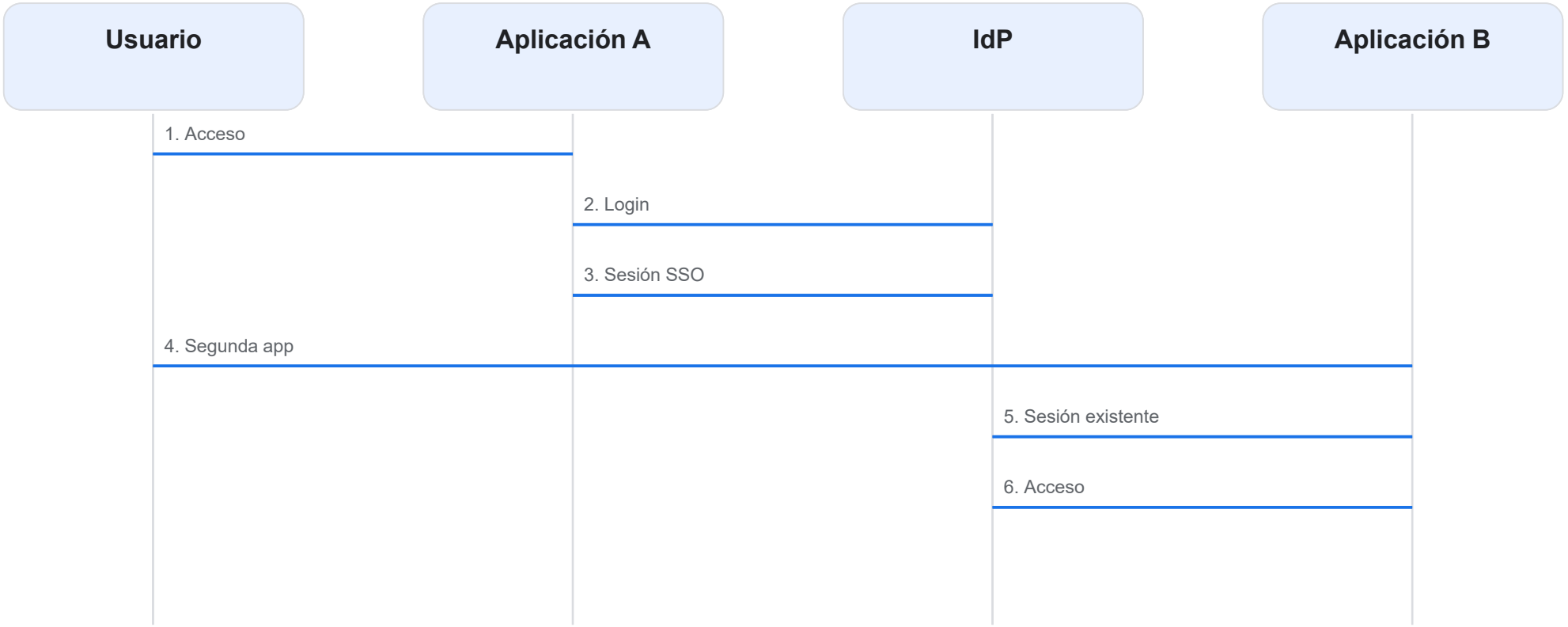
Impacto Operativo y de Seguridad

• Puede reducir la fatiga de contraseñas y la carga de soporte.

• Puede facilitar SLO según protocolo, integración y compatibilidad.

• Riesgo centralizado: Si la cuenta carece de MFA robusto, el robo de credenciales compromete todas las aplicaciones conectadas.

Diagrama de Funcionamiento de SSO con Múltiples Aplicaciones



Federación de Identidades y Relaciones de Confianza

El Modelo de Federación

• Extiende la gestión de identidades a través de distintos límites organizacionales.

• Identity Provider (IdP): Autoridad que autentica al usuario (ej. Empresa A).

• Service Provider (SP / RP): Sistema que provee el servicio (ej. Proveedor SaaS B).

• Reduce la necesidad de credenciales locales, pero pueden existir cuentas vinculadas o aprovisionadas.

La Relación de Confianza Criptográfica

• No se comparten contraseñas ni hashes entre organizaciones.

• Se intercambian metadatos públicos de configuración.

• El SP valida las aserciones mediante la clave pública o JWKS del IdP.

• La identidad se transporta en aserciones firmadas criptográficamente.

Diferencias Conceptuales entre SSO y Federación

Single Sign-On (SSO)

• Alcance: Típicamente dentro de un mismo dominio o perímetro administrativo.

• Objetivo: Evitar múltiples inicios de sesión al usuario final.

• Mecanismo: Sesión centralizada mediante cookies o tickets (Kerberos/CAS).

• Relación: Es una experiencia de usuario / control de sesión.

Federación de Identidades

• Alcance: Interconexión entre múltiples dominios y entidades legales ajenas.

• Objetivo: Portabilidad de la identidad y gobernanza descentralizada.

• Mecanismo: Protocolos estandarizados (SAML 2.0, OpenID Connect).

• Federación y SSO pueden combinarse, pero ninguno garantiza necesariamente al otro.

Introducción Conceptual a OIDC y SAML 2.0

SAML 2.0 (OASIS, 2005)

- Formato de datos basado en XML y firmas XML-DSig.
- Transporte mediante redirecciones HTTP y HTTP POST Bindings.
- Estándar consolidado en el sector corporativo, bancario y gubernamental.
- Aserciones monolíticas que combinan autenticación y atributos.

OpenID Connect 1.0 (OIDF, 2014)

- Capa de identidad construida sobre OAuth 2.0.
- Formato ligero basado en JSON Web Tokens (JWT).
- Diseñado nativamente para arquitecturas web, SPAs, móviles y APIs REST.
- Menor sobrecarga de red y parseo nativo en navegadores modernos.

Desmitificando: OAuth 2.0 vs OIDC vs SAML 2.0

OAuth 2.0 (RFC 6749 / RFC 9700)

- Framework de autorización delegada; también admite accesos máquina a máquina.
- NO es un protocolo de autenticación.
- Permite a una app acceder a recursos en nombre de un usuario.
- El Access Token no define formalmente quién es el usuario.

OpenID Connect 1.0 (OIDC)

- Capa de AUTENTICACIÓN construida sobre OAuth 2.0.
- Introduce el ID Token para transmitir la identidad del usuario.
- Estandariza endpoints de descubrimiento y /userinfo.
- Cubre la carencia de autenticación de OAuth 2.0 original.

SAML 2.0 (OASIS)

- Estándar de aserciones de autenticación, atributos y decisiones de autorización; no equivale a OAuth.
- Emplea aserciones XML complejas.
- Dominante en aplicaciones empresariales heredadas.

Tokens y Aserciones: ID Token, Access Token y Refresh Token

ID Token (OIDC)

• Destinatario: Aplicación Cliente (Frontend).

• Propósito: Probar que el usuario se autenticó.

• Contenido: Claims de perfil (sub, email, auth_time).

• No utilizar el ID Token como credencial de acceso a una API.

Access Token (OAuth 2.0)

• Destinatario: Resource Server (APIs / Microservicios).

• Propósito: Autorizar el acceso a recursos protegidos.

• Claims según perfil de token; no todos los Access Tokens son JWT.

• Se transporta en el header HTTP Authorization: Bearer.

Refresh Token & SAML

• Refresh Token: Artefacto seguro para renovar Access Tokens vencidos.

• SAML Assertion: aserción XML con declaraciones de autenticación, atributos o autorización; no es equivalente a dos tokens OAuth/OIDC.

¿Qué es un Identity Provider (IdP)?

Responsabilidades Centrales del IdP

• Puede centralizar o federar la autenticación de múltiples aplicaciones.

• Presentación y orquestación de desafíos MFA.

• Custodia de claves privadas para la firma de tokens.

• Gestión y persistencia de las sesiones SSO activas.

• Exposición estandarizada de endpoints OpenID Connect y SAML.

Límites Arquitectónicos (Lo que NO es)

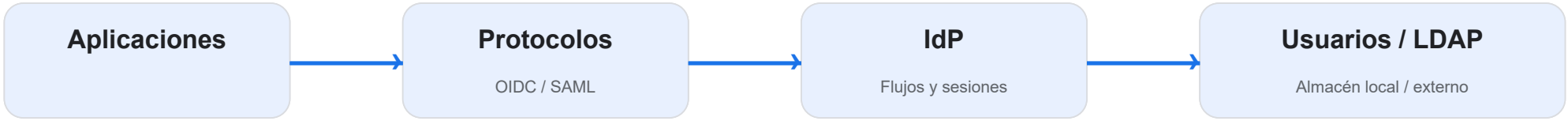
• No es un API Gateway (no enruta paquetes de negocio).

• No sustituye las decisiones de negocio de las aplicaciones; algunos IdP ofrecen servicios de autorización.

• No reemplaza la base de datos de las aplicaciones.

• Ejemplos líderes: Keycloak, Microsoft Entra ID, Okta, Ping Identity, IBM Verify.

Arquitectura de un IdP: Usuarios, Clientes, Sesiones y Criptografía



User Federation: Definición y Propósito

¿Qué es User Federation?

• Mecanismo propio de plataformas IdP (notablemente en Keycloak).

• Integra almacenes externos de cuentas (LDAP v3, Active Directory, BBDD).

• Consulta o sincroniza usuarios directamente al directorio corporativo.

• La validación de credenciales depende del proveedor federado y del modo configurado.

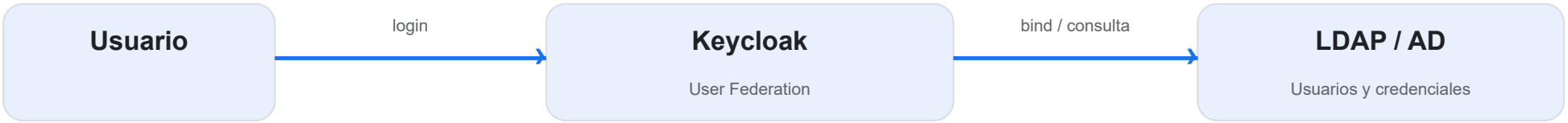
Propósito de Arquitectura

• Aprovechar la infraestructura de directorio existente sin migraciones masivas.

• Modernizar aplicaciones: las apps hablan OIDC con Keycloak mientras las cuentas siguen en Active Directory.

• Diferenciación: Conecta almacenes de datos, NO proveedores de identidad externos.

User Federation con LDAP / Active Directory en Keycloak



Keycloak expone OIDC/SAML a las aplicaciones; el almacén externo sigue siendo la fuente de usuarios.

Identity Brokering: Concepto, Propósito y Funcionamiento

¿Qué es Identity Brokering?

• Intermediación donde el IdP delega la autenticación a un IdP externo.

• El IdP principal actúa como un 'Broker' (intermediario o proxy de identidad).

• Se conecta a IdPs corporativos (Microsoft Entra ID, Okta) o sociales (Google, GitHub).

• Puede interoperar entre protocolos, emitiendo tokens propios tras validar la identidad externa.

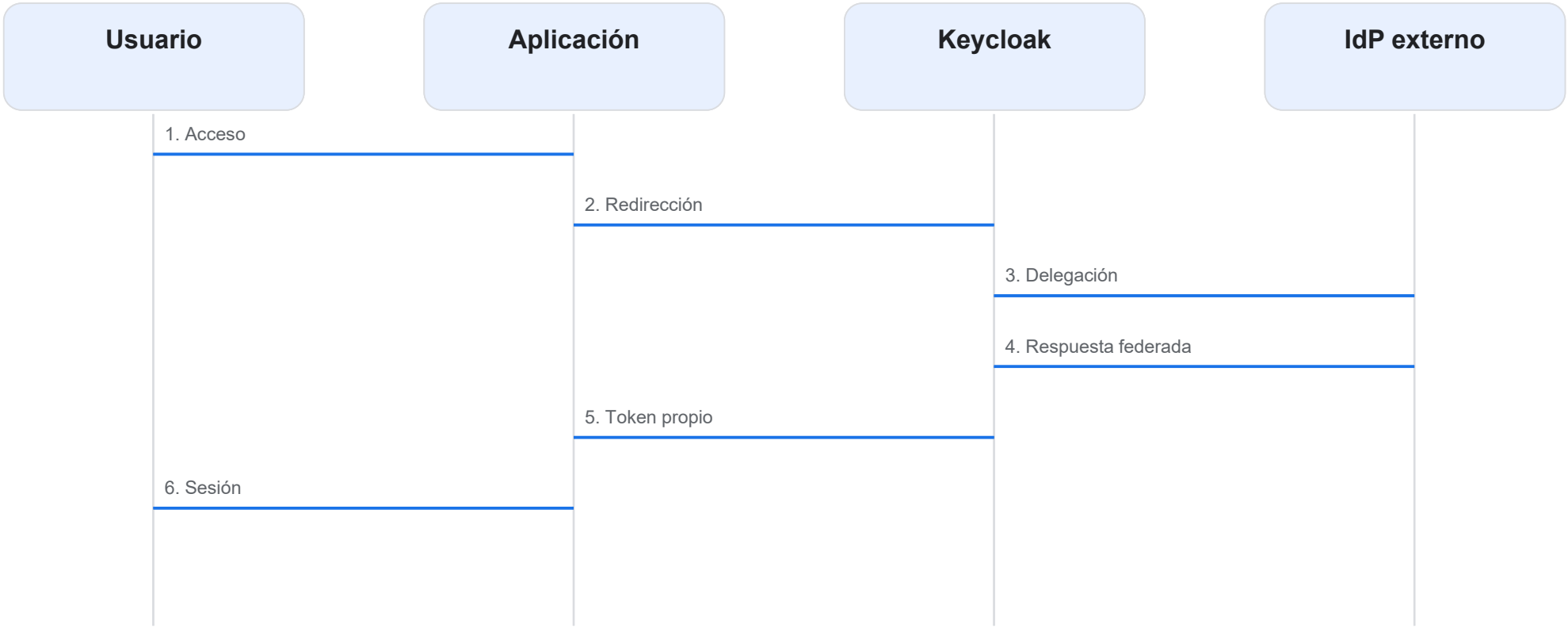
Ventajas Estratégicas

• Desacoplamiento radical: Las aplicaciones internas solo conocen al Broker local.

• Aislamiento de cambios: Si un socio comercial cambia su IdP de SAML a OIDC, las aplicaciones internas no requieren ajustes.

• Habilita escenarios B2B multitenant complejos.

Diagrama de Secuencia de Identity Brokering



Comparación y Ejercicio: IdM, IdP, User Fed y Brokering

Matriz Conceptual Definitiva

• IdM: Gestiona ciclo de vida y aprovisionamiento (SCIM, bases de datos).

• IdP: Emite tokens y autentica en tiempo de ejecución (OIDC, SAML).

• User Federation: Conecta repositorios de cuentas locales (LDAP, Active Directory).

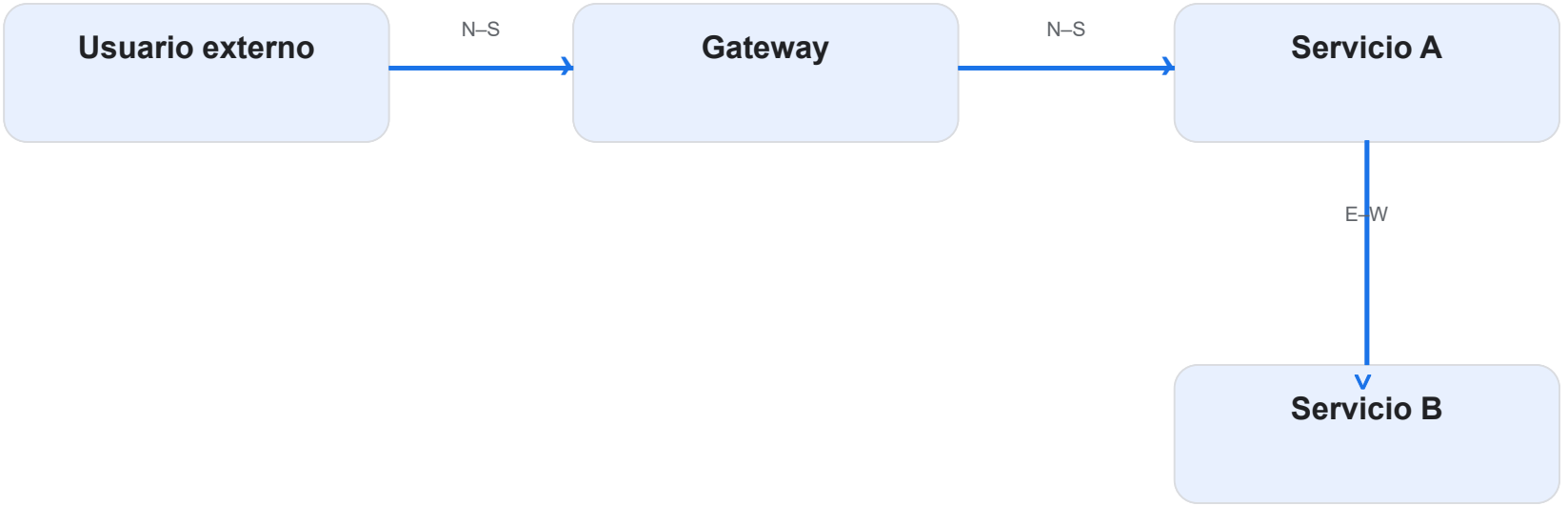
• Identity Brokering: Intermedia con proveedores de identidad externos ajenos.

Ejercicio Práctico de Diseño (2 minutos)

• Caso A: 'Requerimos que 2.000 empleados usen su cuenta de Windows AD local para una nueva app web'. ► ¿Qué corresponde? (Respuesta: User Federation vía LDAP en Keycloak).

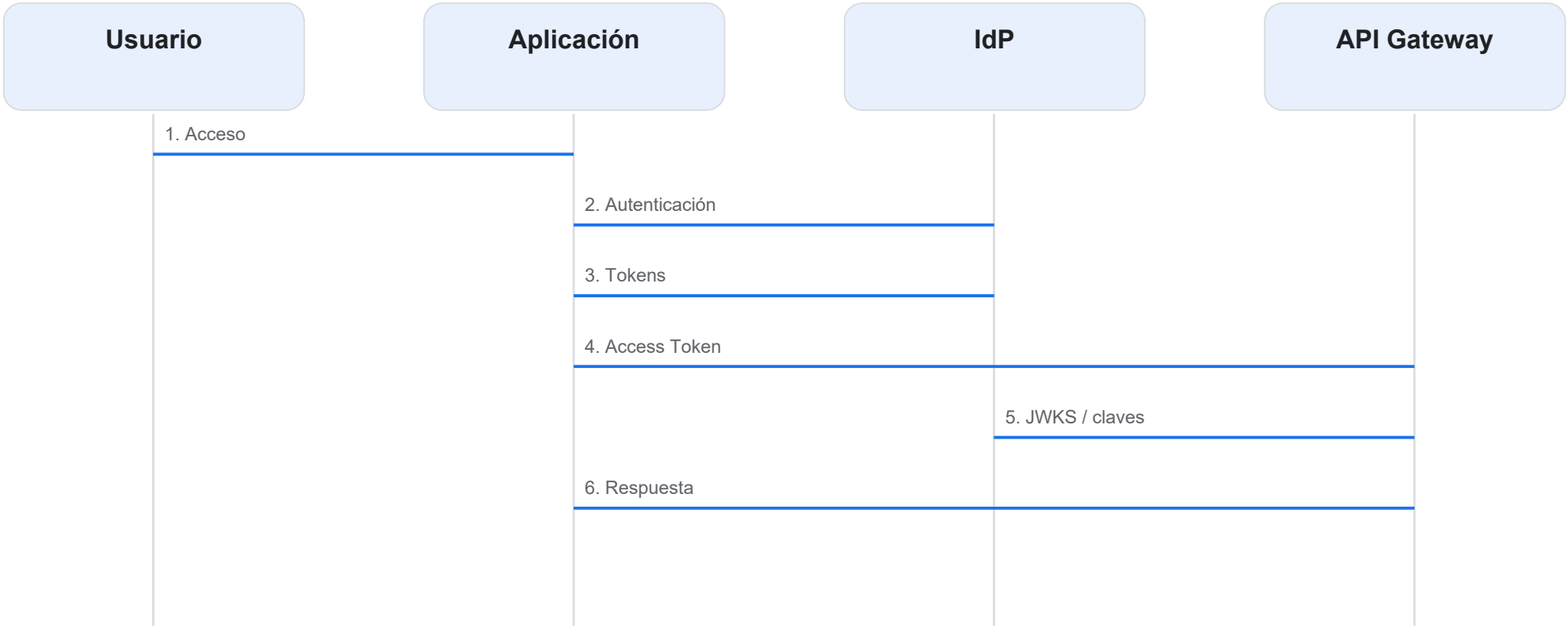
• Caso B: 'Deseamos que socios comerciales accedan a nuestro portal usando sus propias cuentas de Microsoft 365'. ► ¿Qué corresponde? (Respuesta: Identity Brokering federando con Entra ID).

Tráfico North-South y East-West: Definición y Fronteras

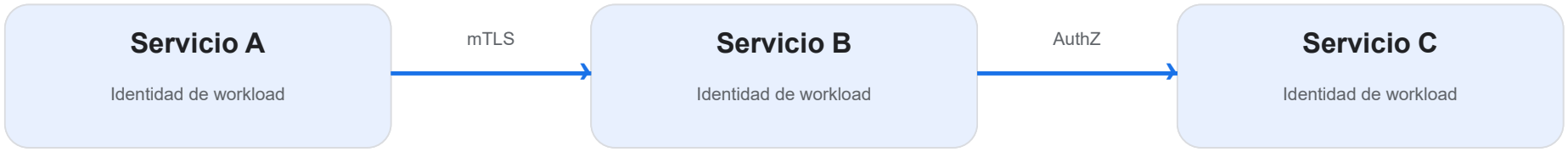


Dirección de tráfico ≠ mecanismo de autenticación

Autenticación y Autorización North-South



Autenticación y Autorización East-West



mTLS autentica el canal • OAuth 2.0 puede aportar tokens • cada recurso aplica su política

Comparación Sistemática: North-South versus East-West

NORTH–SOUTH

Usuario → Entrada → Servicio

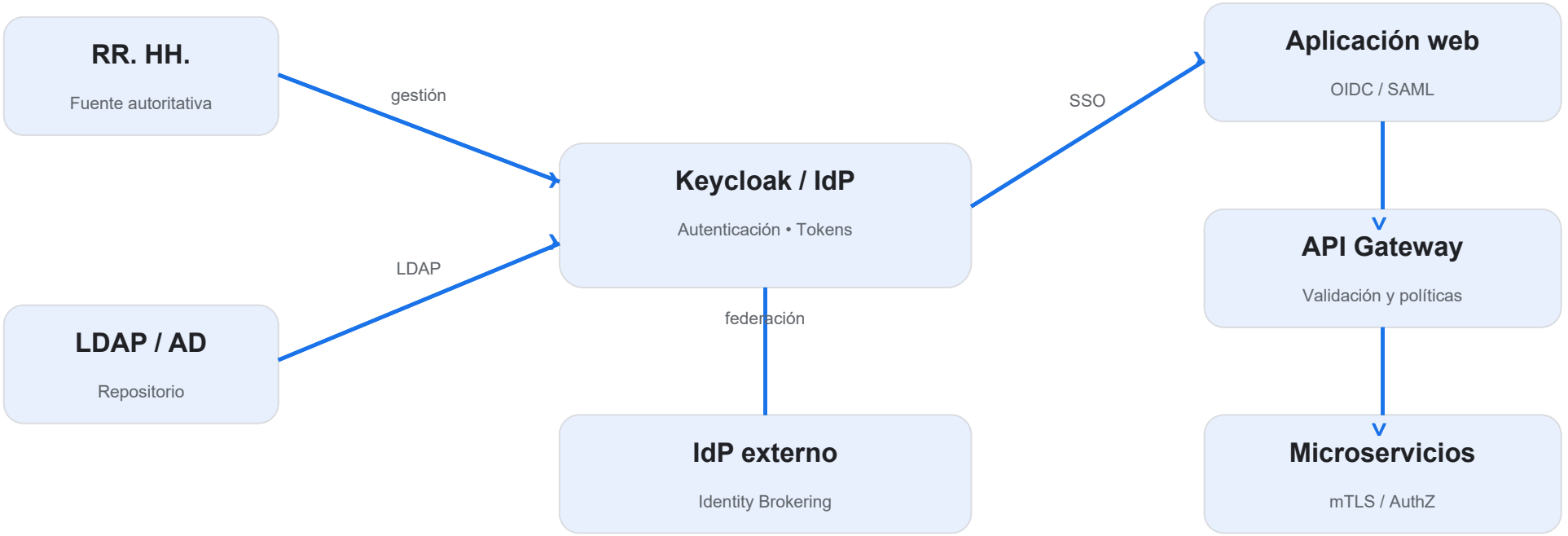
SSO, OIDC, API Gateway, autorización

EAST–WEST

Servicio → Servicio

Workload identity, mTLS, tokens, políticas

Arquitectura Conceptual IAM Integrada



Síntesis Final y Ruta Hacia Keycloak

Fundamentos Consolidados Hoy

- Identidad ≠ Cuenta ≠ Credencial ≠ Rol.
- Autenticación (IdP) ≠ Autorización (PEP/PDP).
- Single Sign-On (Sesión) ≠ Federación (Interdominio).
- User Federation (LDAP/AD) ≠ Identity Brokering (IdP externo).

Lo que Veremos en el Siguiente Módulo

- Organización multitenant: Configuración de REALMS.
- Modelado de aplicaciones: Configuración de CLIENTS.
- Gobierno de usuarios: Gestión de USERS y GROUPS.
- Estructura de acceso: Creación y mapeo de ROLES.
- Seguridad personalizada: Diseño visual de AUTHENTICATION FLOWS.